

Hướng dẫn Báo cáo Bài tập lớn

Cấu trúc, định dạng và tiêu chí đánh giá

ThS. Vũ Quang Dũng

Khoa Hệ thống thông tin – Trường Đại học Phenikaa

CSE703093 – An toàn phần mềm

- 1 Yêu cầu chung về Báo cáo
- 2 Chi tiết từng phần
- 3 Định dạng kỹ thuật và Nộp bài

Mục đích của Báo cáo

- Báo cáo là bằng chứng **chính** để giảng viên đánh giá bài tập lớn (không thuyết trình) – cần **tự giải thích đầy đủ**, không dựa vào phần trình bày miệng
- Một báo cáo tốt giúp người đọc (kể cả không xem mã nguồn) hiểu: bạn đã làm gì, tại sao làm vậy, và kết quả có ý nghĩa gì
- Đây cũng là kỹ năng nghề nghiệp quan trọng: viết báo cáo kỹ thuật rõ ràng là yêu cầu phổ biến trong công việc thực tế

Định dạng và Độ dài

Định dạng file	PDF (khuyến khích biên soạn bằng $\text{\LaTeX}$ hoặc Word)
Độ dài	10–20 trang nội dung chính (không tính phụ lục mã nguồn)
Ngôn ngữ	Tiếng Việt (thuật ngữ kỹ thuật có thể giữ nguyên tiếng Anh kèm giải thích)
Font chữ	Times New Roman/Latin Modern 12pt hoặc tương đương, giãn dòng 1.5

Cấu trúc tổng thể Báo cáo



1. Trang bìa và Mục lục

Trang bìa cần có:

- Tên trường/khoa, tên học phần (CSE703093 – An toàn phần mềm)
- Tên đề tài bài tập lớn (ngắn gọn, mô tả đúng nội dung)
- Họ tên, mã số sinh viên, lớp
- Giảng viên hướng dẫn, học kỳ

Mục lục tự động (dùng tính năng $\LaTeX$ /Word), có số trang chính xác.

2. Giới thiệu & Mục tiêu – Nội dung cần có

- Bối cảnh: vì sao chọn đề tài này (liên hệ tới rủi ro/lỗ hỏng thực tế đã học)
- Mục tiêu cụ thể: liệt kê rõ ràng (vd: "phát hiện tối thiểu 2 lỗi bộ nhớ", "chứng minh thuộc tính an toàn X bằng BMC")
- Phạm vi: nêu rõ những gì **sẽ** và **sẽ không** được thực hiện (tránh kỳ vọng sai)

2. Ví dụ đoạn Giới thiệu tốt

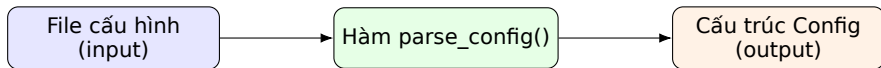
Ví dụ

"Báo cáo này trình bày việc phân tích an toàn bộ nhớ cho một chương trình C xử lý file cấu hình dạng key-value. Mục tiêu: (1) phát hiện lỗi hỏng buffer overflow tiềm ẩn bằng static analysis và ASan, (2) sửa lỗi phát hiện được, (3) xác nhận bằng cách chạy lại công cụ. Phạm vi giới hạn ở module đọc file, không bao gồm module ghi log."

3. Mô tả hệ thống/chương trình mục tiêu

- Mô tả chức năng chính của chương trình (input/output, luồng xử lý tổng quan)
- Sơ đồ kiến trúc/luồng dữ liệu đơn giản (nên có hình vẽ, không chỉ mô tả bằng chữ)
- Nêu rõ **attack surface** (liên hệ Chương 2, mục 2.1): đâu là nơi nhận input từ bên ngoài
- Kích thước/độ phức tạp (số dòng mã, số hàm chính) để người đọc hình dung phạm vi

3. Ví dụ Sơ đồ kiến trúc trong báo cáo



Sơ đồ đơn giản như thế này giúp người đọc nắm được bối cảnh trong vài giây, thay vì phải đọc nhiều đoạn văn mô tả.

4. Phương pháp thực hiện - Nguyên tắc trình bày

- Trình bày **theo từng kỹ thuật/chương đã áp dụng**, mỗi kỹ thuật là một mục con riêng biệt
- Với mỗi kỹ thuật: nêu rõ *tại sao chọn* kỹ thuật này, *cách áp dụng cụ thể* (không chỉ nói "đã dùng static analysis" mà cần chỉ rõ dùng công cụ/module nào, cấu hình ra sao)
- Trích dẫn ngắn gọn module/công cụ đã dùng từ softsec-toolkit nếu có

4. Ví dụ mục "Phương pháp" tốt (Chương 2)

Ví dụ

"Chúng tôi sử dụng module `ch2_memsafe.pattern_scanner` để quét toàn bộ 4 file mã nguồn (`parser.c`, `config.c`, `main.c`, `utils.c`), phát hiện 3 lời gọi hàm `strcpy` không kiểm tra độ dài (xem Bảng 1). Sau đó, biên dịch chương trình với `-fsanitize=address` và chạy với 20 test case (bao gồm input cố ý rất dài) để xác nhận khả năng khai thác thực tế của từng cảnh báo."

4. Tránh lỗi thường gặp: Mô tả mơ hồ

Lưu ý

Tránh viết: "Chúng tôi đã áp dụng kỹ thuật kiểm chứng hình thức để kiểm tra chương trình."

Nên viết: "Chúng tôi mô hình hóa hàm `validate_token()` thành Kripke structure với 5 trạng thái (xem Hình 3), sau đó dùng `ch3_staticsat.bounded_checker` với $k = 10$ để kiểm tra thuộc tính **AG** $\neg \text{bypass_auth}$, đặt completeness threshold tại $k = 6$."

5. Kết quả & Phân tích – Yêu cầu bắt buộc

- Mọi kết quả phải có **bằng chứng cụ thể**: bảng số liệu, log output, ảnh chụp màn hình, hoặc đoạn code counterexample
- Không chỉ liệt kê kết quả – phải **phân tích ý nghĩa**: lỗi này thuộc loại CWE nào? Mức độ rủi ro (Chương 1/2) thế nào? Vì sao công cụ tìm ra được (hay không tìm ra được)?
- Nếu so sánh nhiều kỹ thuật (vd: black-box vs white-box fuzzing), cần bảng so sánh định lượng rõ ràng

5. Ví dụ Bảng kết quả tốt

ID	Lỗi phát hiện	CWE	Công cụ
BUG-01	Buffer overflow trong parse_line() dòng 42	CWE-120	pattern_scanner + ASan
BUG-02	Use-after-free trong free_config() dòng 88	CWE-416	memory_trace

Bảng có cấu trúc rõ ràng giúp

giảng viên chấm điểm nhanh và chính xác hơn nhiều so với văn bản dài dòng.

5. Trình bày Counterexample/Crash cụ thể

```
Input gây crash: "AAAA...AAAA" (128 ký tự 'A')  
Loại lỗi: Stack buffer overflow (ASan xác nhận)  
Vị trí: parser.c:42, hàm parse_line()
```

Luôn trình bày *input cụ thể* gây ra lỗi (không chỉ nói "có lỗi buffer overflow") – đây chính là "bằng chứng" quan trọng nhất trong báo cáo kỹ thuật bảo mật.

6. Thảo luận & Hạn chế

- Trung thực về **giới hạn** của phương pháp đã dùng (vd: "BMC chỉ kiểm tra tới $k = 10$, chưa đạt completeness threshold nên không loại trừ hoàn toàn lỗi ở bước sâu hơn")
- So sánh kết quả với lý thuyết đã học: kết quả có phù hợp với dự đoán từ Chương 1-4 không? Nếu khác, giải thích tại sao
- Đề xuất hướng cải thiện nếu có thêm thời gian/nguồn lực

6. Vì sao phần Hạn chế quan trọng

Định nghĩa

Một báo cáo thừa nhận rõ ràng giới hạn của mình thể hiện **hiểu biết sâu sắc** hơn nhiều so với báo cáo khẳng định "đã chứng minh hoàn toàn an toàn" một cách thiếu căn cứ. Đây trực tiếp phản ánh khái niệm Sound/Complete đã học ở Chương 3.

7. Kết luận, Tài liệu tham khảo, Phụ lục

- **Kết luận:** tóm tắt ngắn gọn (nửa trang) những gì đã đạt được, không lặp lại chi tiết đã trình bày
- **Tài liệu tham khảo:** trích dẫn đầy đủ mọi công cụ, tài liệu, bài báo đã sử dụng/tham khảo (định dạng nhất quán)
- **Phụ lục:** mã nguồn đầy đủ (hoặc link repository), log chi tiết dài, cấu hình công cụ

- Chỉ trích đoạn code **quan trọng, ngắn gọn** (5-20 dòng) minh họa trực tiếp luận điểm đang trình bày
- Dùng định dạng code block có tô màu cú pháp (không dán code thô không định dạng)
- Toàn bộ mã nguồn đầy đủ đặt ở **phụ lục** hoặc nộp kèm file riêng/link repository, không nhồi nhét vào phần nội dung chính

Cấu trúc nộp bài đề xuất

```
MSSV_HoTen_BTL/  
  BaoCao_MSSV_HoTen.pdf  
  source/  
    (toan bo ma nguon chuong trinh muc tieu)  
    (script/module da dung tu softsec-toolkit)  
  results/  
    (log, screenshot, du lieu ket qua tho)  
  README.md    (huong dan chay lai toan bo)
```

Checklist trước khi nộp

- ☐ Báo cáo có đủ 7 phần theo cấu trúc đã hướng dẫn
- ☐ Mọi kết quả đều có bằng chứng cụ thể (log/ảnh/bảng số liệu), không có khẳng định suông
- ☐ Mã nguồn chạy được, có hướng dẫn cài đặt/chạy lại rõ ràng trong README
- ☐ Đã kiểm tra chính tả, định dạng nhất quán, số trang trong mục lục chính xác
- ☐ Tên file/thư mục nộp bài đúng quy định (MSSV, họ tên)

Lưu ý

Mọi đoạn văn/mã nguồn tham khảo từ nguồn bên ngoài (bài báo, GitHub, ChatGPT/AI...) **phải được trích dẫn rõ ràng**. Sao chép không trích dẫn được coi là vi phạm liên chính học thuật, xử lý theo quy định của Nhà trường.

Sử dụng AI hỗ trợ viết code/báo cáo được phép nhưng **phải ghi chú rõ** phần nào có hỗ trợ từ AI và mức độ hỗ trợ.

Bảng tổng hợp Tiêu chí chấm điểm Báo cáo

Tiêu chí	Trọng số
Cấu trúc đầy đủ, rõ ràng, đúng định dạng	15%
Mô tả hệ thống/phương pháp chính xác, chi tiết	25%
Kết quả có bằng chứng cụ thể + phân tích đúng đắn	35%
Thảo luận hạn chế trung thực, sâu sắc	15%
Chất lượng trình bày tổng thể (ngôn ngữ, hình vẽ, bảng biểu)	10%

Ví dụ Mục lục Báo cáo hoàn chỉnh (mẫu tham khảo)

- 1 Giới thiệu và Mục tiêu
- 2 Mô tả chương trình mục tiêu
- 3 Phương pháp: Mô hình hóa (Chương 1)
- 4 Phương pháp: Phân tích bộ nhớ (Chương 2)
- 5 Phương pháp: Kiểm chứng SMT/BMC (Chương 3, nếu áp dụng)
- 6 Phương pháp: Fuzzing (Chương 4, nếu áp dụng)
- 7 Kết quả và Phân tích
- 8 Thảo luận và Hạn chế
- 9 Kết luận
- 10 Tài liệu tham khảo
- 11 Phụ lục: Mã nguồn và Log chi tiết

- Viết báo cáo **song song** với quá trình thực hiện, không dồn vào phút cuối – dễ quên chi tiết quan trọng
- Đọc lại báo cáo với vai trò "người đọc lần đầu, chưa biết gì về đề tài" để phát hiện đoạn nào còn mơ hồ
- Khi nghi ngờ, hãy hỏi: "Kết luận này có bằng chứng cụ thể đi kèm không?"

Chúc các bạn hoàn thành tốt Báo cáo!

Câu hỏi?